VULNERABILITY ASSESSMENT REPORT

Assessment target: Metasploitable 2 – isolated virtual lab machine

Assessment methods: Nmap service discovery and OpenVAS/Nessus vulnerability scanning

Assessment scope: Example lab target only; all IP addresses and scan observations below are illustrative sample results.

1. Executive Summary

A vulnerability assessment was prepared for a deliberately vulnerable virtual machine in an isolated lab. The sample assessment identified several network services that should not be exposed in a production environment, including legacy file-transfer, remote-login, and file-sharing services. One critical issue is associated with the backdoored vsftpd 2.3.4 release described by CVE-2011-2523. If present, this issue can allow an unauthenticated remote attacker to obtain a command shell, putting system confidentiality, integrity, and availability at risk. The overall sample risk is Critical. The system owner should isolate the machine, remove vulnerable services, apply supported updates, and repeat the assessment after remediation.

2. Nmap Port and Service Discovery

Port	Service	Sample version / observation	Risk note
21/tcp	FTP	vsftpd 2.3.4	Critical if backdoored build is present
22/tcp	SSH	OpenSSH 4.7p1	Legacy version; verify patch status
23/tcp	Telnet	Telnet service	Clear-text remote login
25/tcp	SMTP	Mail service	Review relay and service configuration
80/tcp	HTTP	Apache httpd 2.2.8	Legacy web server; verify updates
139/445	SMB	Samba 3.0.20	Review legacy file-sharing exposure
3306/tcp	MySQL	Database service	Restrict network access

Sample Nmap command: **nmap -sV -sC -oN nmap_results.txt [LAB_VM_IP]**

3. Vulnerability Scan Summary

Finding	Severity	Evidence / impact
vsftpd 2.3.4 backdoor (CVE-2011-2523)	**Critical**	Affected backdoored release can open a shell on TCP port 6200, enabling remote command execution.
Telnet clear-text service	**High**	Credentials and session data may be exposed to network observers.
Legacy HTTP / SMB services	**Medium**	Outdated software and unnecessary network exposure may increase attack surface; verify exact versions and applicable CVEs.

High/Critical CVE analysis – CVE-2011-2523: NVD rates this issue 9.8 Critical (CVSS 3.1). The affected case is vsftpd 2.3.4 downloaded between 30 June and 3 July 2011, which contained a backdoor that opens a shell on TCP port 6200. An attacker able to reach the vulnerable FTP service may trigger the backdoor without authentication and execute commands. This could expose files, alter system data, or disrupt the host. The CVE applies to the affected backdoored distribution, not every installation labelled vsftpd 2.3.4. Source: NIST National Vulnerability Database, CVE-2011-2523 – https://nvd.nist.gov/vuln/detail/CVE-2011-2523

4. Prioritized Recommendations

Priority	Finding	Recommended action
1 – Immediate	vsftpd backdoor / CVE-2011-2523	Disconnect the affected host from untrusted networks. Remove the backdoored package and install a verified, trusted, supported FTP server version. If FTP is not required, disable and remove the service. Rebuild the host if compromise is suspected.
2 – High	Telnet service	Disable Telnet and use SSH with secure configuration. Restrict remote administration to trusted management networks.
3 – High	Legacy SMB service	Update Samba to a supported release, disable obsolete SMB protocols, and restrict SMB access to required hosts only.
4 – Medium	Legacy HTTP service	Upgrade the web server and application components to supported versions. Remove unused modules and enforce HTTPS where applicable.
5 – Medium	Database exposure	Restrict database access to application hosts and administrators. Require strong authentication and avoid exposing database ports to public networks.

5. Validation and Retesting

• Apply the fixes in priority order and record the responsible system owner and completion date.

• Repeat Nmap service discovery to confirm that unnecessary ports are closed and required services use supported versions.

• Run OpenVAS or Nessus again and compare the new results with the original findings.

• Close each finding only after the service is verified as fixed or the risk is formally accepted by the system owner.

6. Presentation and Q&A;

Questions and Answers
Q1. Why is CVE-2011-2523 the highest priority? A. It is rated Critical (CVSS 9.8) by NVD and may allow unauthenticated remote command execution on an affected backdoored vsftpd build. It can affect confidentiality, integrity, and availability.
Q2. Does an open port always mean a vulnerability exists? A. No. An open port means a service is reachable. Risk depends on the service, its version, configuration, exposure, and whether a known weakness applies.
Q3. How will the owner know the fixes worked? A. Repeat service discovery and vulnerability scanning, then verify that the vulnerable software is removed or patched and the reported findings are no longer detected.

7. Overall Conclusion

The sample assessment indicates a Critical overall risk because of the potential vsftpd backdoor exposure, along with additional risks from legacy remote-access and network services. The system owner should isolate the host and address the Critical finding first, then remediate the remaining issues and complete a verification scan.